



HACKTHEBOX

Security Incident Report

Phishing Email – PayPal Impersonation

August 21, 2026

Version: 1.0

Table of Contents

1	Statement of Confidentiality	3
2	Engagement Contacts	4
3	Investigation Scope & Objectives	5
4	Executive Summary	6
5	Technical Analysis	8
	PayPal Impersonation Phishing Email	8
A	Appendix	13
	A.1 Technical Timeline	13

1 Statement of Confidentiality

The contents of this document have been developed by Hack The Box. Hack The Box considers the contents of this document to be proprietary and business confidential information. This information is to be used only in the performance of its intended use. This document may not be released to another vendor, business partner or contractor without prior written consent from Hack The Box. Additionally, no portion of this document may be communicated, reproduced, copied or distributed without the prior consent of Hack The Box.

The contents of this document do not constitute legal advice. Hack The Box's offer of services that relate to compliance, litigation or other legal interests are not intended as legal counsel and should not be taken as such. The assessment detailed herein is against a fictional company for training and examination purposes, and the vulnerabilities in no way affect Hack The Box external or internal infrastructure.

2 Engagement Contacts

Contacts		
Primary Contact	Title	Contact Email
Blacksky55	-	Blacksky55@protonmail.me

3 Investigation Scope & Objectives

The investigation focused on the analysis of a suspicious German-language email impersonating PayPal. The objective was to determine whether the email represented a phishing attempt and to identify relevant indicators of compromise (IoCs) associated with the message.

The investigation included analysis of the email headers, sender and return-path information, embedded URLs, associated domains, and external threat-intelligence data. Particular attention was given to identifying inconsistencies between the claimed sender identity and the underlying email infrastructure.

The investigation was limited to the artifacts provided as part of the HTB Sherlock "Phishing_Email" challenge. No assumptions were made regarding successful credential theft, endpoint compromise, or further attacker activity where supporting evidence was not available.

4 Executive Summary

Phishing Email – PayPal Impersonation

Incident ID: HTB-SHERLOCK-Phishing_Email

Incident Severity: Medium

Incident Status: Closed – Investigation Completed

Incident Overview

A suspicious German-language email impersonating PayPal was investigated as part of the Hack The Box Sherlock “Phishing_Email” challenge. The investigation focused on determining whether the email represented a phishing attempt and identifying indicators associated with the message.

The analysis identified multiple inconsistencies between the claimed PayPal identity and the underlying email infrastructure. The message used a non-PayPal sender domain, a suspicious return path, and an embedded URL hosted on Google infrastructure that pointed to a randomly named HTML resource.

Key Findings

- The email's Return-Path was bounce@rjttznzjzydnillquh.designclub.uk.com, which is unrelated to PayPal.
- The displayed sender used the domain kodehexa.net, rather than an official PayPal domain.
- The email contained a URL hosted at storage.googleapis.com, pointing to a randomly named HTML resource.
- The email infrastructure referenced multiple unrelated domains and IP addresses, further supporting the assessment that the message was malicious.
- VirusTotal identified the URL/email activity as phishing through at least one security vendor.
- No evidence was identified within the provided artifacts to confirm successful credential theft, endpoint compromise, or further attacker activity.

Immediate Actions

The suspicious email should be treated as a phishing attempt. The embedded URL should not be accessed, and the identified sender domains, return-path, and URL should be considered indicators for further detection and threat hunting where applicable.

Stakeholder Impact

The primary identified risk is potential user interaction with a fraudulent PayPal-themed email and its embedded URL. Based on the available evidence, successful compromise or data loss could not be established.

PayPal Impersonation Phishing Email

Incident ID: HTB-SHERLOCK-PE-001

Incident Severity: Medium

Incident Status: Complete

Incident Overview:

A suspicious German-language email impersonating PayPal was identified and investigated. The email attempted to appear as a legitimate PayPal communication and contained an embedded URL intended to direct the recipient to an externally hosted HTML resource.

Analysis of the provided paypal.eml artifact identified multiple indicators inconsistent with a legitimate PayPal communication, including a non-PayPal sender domain, a suspicious return path, unrelated mail infrastructure, and an embedded URL hosted on Google Cloud Storage. The available evidence supports the classification of the email as a phishing attempt. No evidence within the provided artifact was identified to confirm successful credential theft, endpoint compromise, or subsequent attacker activity.

Key Findings:

- The email impersonated PayPal but used a non-PayPal sender domain (kodehexa.net) and a return path hosted under designclub.uk.com.
- The email contained an embedded URL pointing to <https://storage.googleapis.com/hayqozqatqthj/aemmfcyvxeo.html>, rather than an official PayPal domain.
- The email headers referenced multiple unrelated domains and mail infrastructure, including vevida.net, foresthillrestaurant.com, and efianalytics.com, which is inconsistent with a legitimate PayPal communication.
- VirusTotal identified the analyzed URL as phishing through security vendor detection, supporting the classification of the email as a phishing attempt.

Immediate Actions:

- Quarantine and remove the identified phishing email from affected mailboxes where applicable.
- Block or monitor the identified phishing indicators, including the sender domain, return-path domain, and embedded URL.
- Prevent users from accessing the identified phishing URL and investigate any observed connections to the URL.
- Review available email and proxy/web logs for additional recipients or users who may have interacted with the identified URL.
- If user interaction with the phishing page is confirmed, perform appropriate account and endpoint investigation to determine whether credentials or other sensitive information may have been exposed.
- Continue monitoring the identified indicators for related phishing activity.

Stakeholder Impact:

The primary stakeholder impact is the potential exposure of recipients to a targeted phishing attempt impersonating PayPal. Recipients who interacted with the email or its embedded URL may have been exposed to credential theft or other malicious activity.

Based on the available evidence, no successful credential compromise, data exfiltration, or endpoint compromise could be confirmed. The potential impact is therefore assessed as limited to the risk posed by user interaction with the phishing email and associated infrastructure.

5 Technical Analysis

PayPal Impersonation Phishing Email

Affected Systems & Data

The investigation identified the following potentially affected systems and data:

- **Recipient email mailbox:** The suspicious PayPal-themed phishing email was delivered to the recipient's email environment. The available evidence does not establish whether the recipient interacted with the message.
- **Email artifact:** The `paypal.eml` file was the primary evidence source and contained the email headers, message body, and embedded phishing URL.
- **Recipient data:** The email was addressed to the recipient identified in the message headers. No evidence was identified indicating that additional personal or confidential data was accessed or exfiltrated.
- **External phishing infrastructure:** The email referenced an HTML resource hosted at `storage.googleapis.com/hayqozqatqthj/aemmfcylvxeo.html`. This infrastructure represents a potential destination for users interacting with the phishing email.

No endpoint compromise, credential theft, data exfiltration, or unauthorized access to other systems could be confirmed from the available evidence.

Evidence Sources & Analysis

The investigation was performed using the artifacts provided with the HTB Sherlock `Phishing_Email` challenge. The primary evidence source was the `paypal.eml` email artifact.

1. Email Artifact Analysis

The `paypal.eml` file was examined as a raw email message to preserve and analyze the original email headers and message content. The analysis focused on sender information, routing information, authentication results, message identifiers, and embedded URLs.

The following observations were identified:

- The email claimed to represent PayPal but used a sender domain associated with `kodehexa.net`.
- The `Return-Path` was `bounce@rjttznyjjzydnillquh.designclub.uk.com`.
- The `Message-ID` referenced the `vevida.net` domain.
- The email headers contained references to additional unrelated mail infrastructure, including `foresthillrestaurant.com` and `efianalytics.com`.
- SPF authentication was observed as passing; however, the authentication result applied to the envelope sender/return-path infrastructure and did not establish that the message originated from PayPal.

These inconsistencies indicated that the claimed sender identity did not correspond with the underlying email infrastructure.

2. Embedded URL Analysis

The email body was searched for HTTP and HTTPS URLs. The identified phishing URL pointed to:

<https://storage.googleapis.com/hayqozqatqthj/aemmfcylvxoe.html>

The URL was analyzed as an indicator rather than accessed directly. The domain storage.googleapis.com is legitimate Google infrastructure; however, the use of a randomly named HTML resource within the context of a PayPal impersonation email was considered suspicious.

3. VirusTotal Analysis

The base URL <https://storage.googleapis.com> was submitted to VirusTotal in accordance with the Sherlock task instructions. The VirusTotal report was reviewed for URL detection and HTTP response information.

VirusTotal identified the activity as phishing through security vendor analysis, supporting the assessment derived from the email artifact.

The Sherlock task also required the historical HTTP response Body SHA-256. The current VirusTotal report available during the investigation returned an HTTP 400 response and did not expose the historical Body SHA-256 in the current interface. Therefore, the historical hash expected by the challenge was treated as challenge-specific evidence rather than independently reproduced from the current VirusTotal response.

4. Assessment

The combination of inconsistent email routing information, a non-PayPal sender domain, an externally hosted HTML resource, and phishing detection by VirusTotal supports the conclusion that the analyzed email was a phishing attempt impersonating PayPal.

No evidence was identified within the provided artifacts demonstrating successful credential theft, endpoint compromise, persistence, lateral movement, or data exfiltration.

Indicators of Compromise (IoCs)

The following indicators were identified during analysis of the phishing email and may be used for detection and threat hunting:

Type	Indicator	Context
Email Address / Return-Path	bounce@rjttznyzjjzydnillquh.designclub.uk.com	Return path identified in the phishing email
Sender Domain	kodehexa.net	Domain used by the apparent sender
Message-ID Domain	vevida.net	Domain referenced by the email Message-ID
URL	https://storage.googleapis.com/hayqozqatqthj/aemmfcylvxoe.html	External HTML resource referenced by the email
Domain	storage.googleapis.com	Hosting infrastructure used by the embedded URL

Type	Indicator	Context
IP Address	134.195.196.43	IP address observed in the email's Received header
IP Address	216.244.76.116	IP address observed in the email's Received header
SHA-256	13945ecc33afee74ac7f72e1d5bb73050894356c4bf63d02a1a53e76830567f5	Body SHA-256 associated with the historical VirusTotal response referenced by the Sherlock

These indicators should be considered in context. In particular, storage.googleapis.com is legitimate Google infrastructure and should not be treated as malicious solely based on its presence. Detection should focus on the specific URL and its relationship to the phishing email.

The identified sender and infrastructure domains should be monitored for additional phishing activity where appropriate.

Root Cause Analysis

The root cause of the incident was a phishing campaign designed to impersonate PayPal and deceive the recipient into interacting with an externally hosted resource.

The attacker relied primarily on **social engineering and brand impersonation** rather than exploiting a technical vulnerability in the recipient's environment. The email was crafted to appear as a legitimate PayPal communication while using infrastructure unrelated to PayPal. This included a non-PayPal sender domain, a separate return-path domain, and additional unrelated domains within the email delivery path.

The phishing message contained an embedded URL pointing to an HTML resource hosted on Google Cloud Storage:

<https://storage.googleapis.com/hayqozqatqthj/aemmfcylvxeo.html>

The use of legitimate cloud hosting infrastructure provided the attacker with an externally accessible location for the phishing resource while avoiding the use of an obviously malicious or newly registered domain in the visible URL.

The underlying failure point was therefore **user-targeted social engineering combined with the use of external hosting infrastructure**, rather than a confirmed vulnerability or compromise of the recipient's systems.

No evidence was identified in the supplied artifacts demonstrating successful user interaction with the phishing resource, credential submission, malware execution, persistence, lateral movement, or data exfiltration. Consequently, the investigation cannot establish that the phishing attempt resulted in a successful compromise.

The available evidence supports the following root-cause chain:

Phishing email → PayPal impersonation → deceptive external URL → potential user interaction → potential credential or information disclosure

Only the first three stages are directly evidenced by the supplied artifacts; the subsequent stages remain potential outcomes that could not be confirmed during this investigation.

Technical Timeline

The available evidence does not provide reliable timestamps for each stage of the phishing activity. The timeline below therefore distinguishes between the timestamp contained in the email artifact and activities reconstructed from the available evidence.

Time / Order	Activity	Evidence / Analysis
1	Phishing email generated / sent	The Date header in paypal.eml indicates 15 August 2022 . The email impersonated PayPal and was written in German.
2	Email delivery	Multiple Received headers document mail infrastructure involved in delivery, including 134.195.196.43 and 216.244.76.116 .
3	Phishing email received	The message was delivered to the recipient mailbox and contained both plain-text and HTML versions of the message.
4	Phishing URL presented	The HTML email contained a link to https://storage.googleapis.com/hayqozqatqthj/aemmfcylvxeo.html , an externally hosted HTML resource.
5	Phishing infrastructure identified	Analysis identified inconsistencies between the claimed PayPal identity and the sender, return-path, Message-ID, and delivery infrastructure.
6	Threat intelligence analysis	The URL/domain was investigated using VirusTotal. Security vendor analysis identified the activity as phishing.
7	Incident assessment	The available evidence supported classification of the email as a phishing attempt. No evidence confirmed credential theft, malware execution, persistence, lateral movement, or data exfiltration.

Kill Chain Mapping

Kill Chain Stage	Assessment
Reconnaissance	Not evidenced
Initial Access	Phishing email delivery evidenced
Execution	Not evidenced
Persistence	Not evidenced
Privilege Escalation	Not evidenced
Defense Evasion	Not evidenced
Credential Access	Potential objective; not confirmed
Discovery	Not evidenced
Lateral Movement	Not evidenced
Collection	Not evidenced
Command & Control	Not evidenced

Kill Chain Stage	Assessment
Exfiltration	Not evidenced
Impact	Potential credential/information exposure; not confirmed

The investigation establishes the delivery and phishing nature of the email but does not provide sufficient evidence to reconstruct activity beyond the phishing attempt itself.

Nature of the Attack

The incident represents a **phishing attack using PayPal brand impersonation and a malicious external URL**. The attacker attempted to establish trust by presenting the email as a legitimate PayPal communication in German and directing the recipient toward an externally hosted HTML resource.

The attack primarily relied on **social engineering** rather than exploitation of a technical vulnerability. Several characteristics of the message were inconsistent with a legitimate PayPal communication, including the use of a non-PayPal sender domain, a separate return-path domain, unrelated email infrastructure, and an embedded URL hosted outside the PayPal domain.

The identified URL was hosted on Google Cloud Storage:

<https://storage.googleapis.com/hayqozqatqthj/aemmfcy1vxeo.html>

The use of a legitimate cloud service for hosting the phishing resource is consistent with an attempt to make the destination appear less obviously malicious and to leverage trusted infrastructure.

Observed Tactics, Techniques and Procedures

- **Phishing:** Delivery of a deceptive email intended to persuade the recipient to interact with attacker-controlled or attacker-associated content.
- **Spearphishing Link (T1566.002):** The email contained a link to an externally hosted HTML resource rather than requiring a malicious attachment.
- **Masquerading / Brand Impersonation (T1036):** The email attempted to impersonate PayPal to establish credibility with the recipient.
- **Abuse of Legitimate Services:** The phishing URL was hosted using Google Cloud Storage infrastructure.
- **Credential Phishing:** Credential theft is a plausible objective of the phishing activity; however, the supplied evidence does not confirm that credentials were actually submitted or obtained.

No evidence was identified for malware execution, persistence, privilege escalation, lateral movement, command and control, or data exfiltration. The observed attack therefore appears to have ended at the phishing-delivery stage within the available evidence.

A Appendix

A.1 Technical Timeline

Time	Activity
2022-08-15	The suspicious German-language email impersonating PayPal was dated and delivered to the recipient mailbox.
T+0	The email was analyzed as a raw <code>.eml</code> artifact, including its headers, routing information, and message body.
T+1	The <code>Return-Path</code> and sender information were identified as inconsistent with a legitimate PayPal communication.
T+2	Multiple unrelated domains and IP addresses were identified within the email's <code>Received</code> headers and message metadata.
T+3	An embedded URL pointing to <code>https://storage.googleapis.com/hayqozqatqthj/aemmfcylvx eo.html</code> was identified.
T+4	The base URL/domain was investigated using VirusTotal in accordance with the Sherlock task instructions.
T+5	VirusTotal security vendor analysis supported the classification of the activity as phishing.
T+6	The investigation concluded that the email represented a PayPal impersonation phishing attempt. No evidence of successful credential theft, endpoint compromise, persistence, lateral movement, or data exfiltration was identified.

End of Report

*This report was rendered
by SysReptor with
♥*